Nota de portafolio: este informe es una auditoría real realizada con fines académicos. El nombre de la empresa y los nombres de usuario/equipo del personal han sido sustituidos por valores ficticios para proteger la identidad del cliente real y de las personas afectadas, conforme a la confidencialidad profesional y al RGPD. Las direcciones IP mostradas son privadas (RFC 1918, 192.168.1.0/24) y no identifican por sí solas ninguna organización. La metodología, los hallazgos, su severidad y las correcciones propuestas son fieles al trabajo original.

CONFIDENCIAL

Auditoría de seguridad interna — MoldTek Industrial

Reconocimiento no intrusivo de red interna · MSA-Interno

Objetivo	Red interna de MoldTek Industrial, rango `192.168.1.0/24` (confirmado por evidencia propia, 92 hosts activos — ver §6)
Modalidad	Reconocimiento interno no intrusivo (sin explotación, sin captura de tráfico, sin manipulación de protocolo)
Punto de acceso	Acceso remoto por RDP a una máquina de pruebas Windows (`testclient`, usuario `rdp.prueba`) conectada por Ethernet al segmento objetivo
Fecha de ejecución	6 de octubre de 2026
Autorización	Ejercicio académico (práctica MSA) realizado bajo el mismo marco de autorización y alcance que el informe de reconocimiento externo de latabernademo.com
Auditores	Xavier Margalef
Versión del documento	1.0
Clasificación	Informe de muestra de portafolio — datos del cliente real anonimizados

Índice

1. Parte I — Informe ejecutivo
    1. Riesgo global y conclusión
    2. Hallazgos, riesgo e impacto normativo
    3. Prioridades de corrección
2. Parte II — Informe técnico
    1. Metodología — MSA-Interno
    2. Topología de red identificada
    3. Desarrollo del reconocimiento
    4. Hallazgos técnicos

5. Cobertura y cierre
6. Decisiones y límites de alcance
3. Anexos: normativa, glosario, referencias

PARTE I — INFORME EJECUTIVO

1. RIESGO GLOBAL Y CONCLUSIÓN

Riesgo global: MEDIO **.** No hay vulnerabilidad crítica confirmada ni evidencia de explotación activa. El problema de fondo no es una única vulnerabilidad grave, sino la combinación de tres patrones que se repiten: credenciales de administración sin cifrar en al menos un dispositivo (impresora), infraestructura crítica (iDRAC, hipervisores, NAS) sin segmentar del resto de la red de usuario, y un servidor con CVE conocido sin parchear desde hace más de un año. Ninguno por separado es "Alto", pero juntos describen una red sin higiene de gestión de activos ni segmentación — el patrón de riesgo típico que precede a un incidente serio, no un hallazgo puntual.

Superficie de movimiento lateral: el hallazgo con más impacto estructural no es ninguno individual, sino su combinación. MAT-05 confirma que no existe segmentación entre los puestos de usuario y la infraestructura crítica (iDRAC, hipervisores ESXi, NAS); MAT-07 confirma que, además, el propio Controlador de Dominio expone su interfaz de administración remota (RDP) a ese mismo segmento. En la práctica, esto significa que el compromiso de un solo puesto de usuario corriente —por ejemplo vía phishing, aunque esa vía de entrada concreta no se evalúa en este ejercicio (ver §9)— tendría conectividad L3 directa tanto a la gestión fuera de banda de los servidores físicos como al propio DC, sin ningún salto de red intermedio que lo impida. La correlación MITRE ATT&CK de §7 detalla las técnicas concretas (T1021, T1021.001, T1210) a las que queda expuesta esta cadena.

DATO	VALOR
Rango de red	`192.168.1.0/24`, zona AD `local.internal`
Hosts activos	92 (confirmados por ARP, MI1)
Hallazgo más grave	Credenciales de administración en texto claro — impresora Canon LBP710Cx (MAT-04)
Protocolos obsoletos detectados	Ninguno activo en el servidor principal (FTP/Telnet cerrados); HTTP sin TLS en 2 de 7 hosts inspeccionados
Activos críticos/frágiles identificados	4 hipervisores ESXi y 1 iDRAC compartiendo red plana con los puestos de usuario, sin VLAN de gestión (MAT-05)

2. HALLAZGOS, RIESGO E IMPACTO NORMATIVO

Cada fila es un hallazgo del ejercicio, identificado como **MAT-01 a MAT-07** (numeración correlativa propia de este informe, en el orden en que se documentó — no es un identificador CVE ni un estándar externo). El detalle completo de cada uno, con comandos y evidencia, está en la Parte II, §7.

ID	HALLAZGO	SEVERIDAD	CVSS	IMPACTO SI NO SE CORRIGE	NORMATIVA	ESTADO
MAT-04	Credenciales de administración de impresora en texto claro (HTTP)	MEDIO	5.9	Captura de credenciales de administración del dispositivo por cualquiera en el mismo segmento	ISO 27001 A.8.24; RGPD Art. 32	Abierto
MAT-05	Sin segmentación entre puestos de usuario e interfaces de gestión crítica (iDRAC, ESXi, NAS)	MEDIO	N/A	Un puesto de usuario comprometido da acceso directo a toda la infraestructura crítica	ISO 27001 A.8.22; ENS mp.com	Abierto
MAT-06	Servidor Ubuntu/Apache 2.4.58 sin configurar, con CVE-2024-24795 sin parchear	MEDIO	6.3	HTTP response splitting si se publica una app real sin actualizar antes; además indica un activo sin dueño claro	ISO 27001 A.8.8	Abierto
MAT-07	RDP del Controlador de Dominio accesible desde la red general, sin restricción	MEDIO	N/A	Amplía la superficie de ataque sobre el activo más crítico del dominio (credenciales e identidad)	ISO 27001 A.8.22; ENS mp.com	Abierto
MAT-01	SMB expuesto en el servidor principal, versión sin confirmar	BAJO (A REVISAR)	N/A	Si fuera SMBv1, vector histórico de EternalBlue/WannaCry	ENS op.exp.4	Abierto
MAT-03	Hipervisores ESXi con al menos 2 niveles de parcheo distintos en el mismo clúster	BAJO	N/A	El host menos actualizado del grupo concentra más CVE sin corregir	ISO 27001 A.8.8	Abierto
MAT-02	Servidor IIS interno sin TLS (HTTP puro)	BAJO	N/A	Tráfico posterior a la autenticación sin cifrar (la autenticación en sí no es texto claro)	ISO 27001 A.8.24	Abierto

3. PRIORIDADES DE CORRECCIÓN

1. **Credenciales de impresora en claro** (MAT-04) — habilitar HTTPS en la interfaz de gestión o restringirla a VLAN de administración. Coste bajo, cierra el hallazgo más concreto.

2. **Segmentación de gestión crítica** (MAT-05) — crear VLAN dedicada para iDRAC/ESXi/NAS. Es la corrección estructural con más impacto de todo el informe.
3. **Restringir el acceso RDP al Controlador de Dominio** (MAT-07) — limitarlo a un jump host o VLAN de administración; mismo principio que MAT-05, sobre el activo más crítico de todos.
4. **Parchear o dar de baja el servidor Apache huérfano** (MAT-06) — identificar propietario; si no está en uso, apagarlo.
5. **Confirmar versión SMB del servidor principal** (MAT-01) — una comprobación de 5 minutos con acceso administrativo.
6. **Uniformizar el nivel de parche del clúster ESXi** (MAT-03) — alinear todos los hosts al build más reciente confirmado.

PARTE II — INFORME TÉCNICO

4. METODOLOGÍA — MSA-INTERNO

Adaptación del framework MSA-Recon a un escenario de red interna, manteniendo su misma lógica (fases enumeradas, cada hallazgo trazable a un comando y su salida). Referencias de base: PTES (fases de *Intelligence Gathering* y *Vulnerability Analysis*, sin entrar en *Exploitation*), NIST SP 800-115 (técnicas de identificación y análisis de objetivos, no intrusivas), ISO/IEC 27001:2022 Anexo A (A.8 gestión de activos, A.5.7 inteligencia de amenazas), ENS/CCN-STIC (gestión de comunicaciones internas y segmentación).

FASE	PREGUNTA QUE RESPONDE	TÉCNICA
MI 1	Topología	¿Qué equipos hay, qué IP y qué servicios exponen? — descubrimiento de host + `nmap -sS -sV -Pn -T2/-T3` por rango, banner grabbing HTTP/HTTPS
MI 2	DNS interno	¿Qué servidor DNS, y está mal configurado? — `nslookup` / `dig` contra el DNS interno; comprobación de recursión abierta y transferencia de zona (AXFR) como consulta de lectura
MI 3	DHCP	¿Qué servidor DHCP y hay señales de mala configuración? — observación pasiva de la concesión ya asignada (`ipconfig /all` / `ip a`), sin solicitar leases adicionales
MI 4	Protocolos obsoletos	¿Hay SMBv1, FTP, Telnet, HTTP sin TLS, TLS obsoleto? — detección de versión de protocolo/servicio vía banner, sin scripts de explotación
MI 5	Credenciales en tránsito inseguro	¿Algún servicio transmite credenciales en claro? — identificación del protocolo (FTP/Telnet/HTTP Basic sin TLS, SNMP con community string por defecto) por banner, sin captura de tráfico real

MI6	Vulnerabilidades del escaneo	¿Qué CVE conocidos aplican a las versiones identificadas? — cruce de cada versión de software/firmware contra NVD/Wordfence/avisos del fabricante

Reglas de compromiso: timing conservador (`-T2` / `-T3` , nunca `-T4` / `-T5`); sin categorías NSE `vuln` / `exploit` / `brute` / `dos` ; sin DHCP starvation, ARP spoofing/MITM, rogue DHCP/DNS ni deauth de Wi-Fi; sin captura de tráfico real ni intentos de acceso con credenciales (ni por defecto ni por fuerza bruta); sin explotación de ningún CVE identificado en MI6 — solo correlación documental; prioridad reducida de sondas sobre activos frágiles (equipo embebido, hipervisores sin soporte).

Dos principios transversales: *No intrusión* — todo MI1-MI6 es pasivo o de huella mínima, reforzado explícitamente por instrucción del cliente. *Trazabilidad* — ningún dato se documenta sin decir de dónde sale y con qué otro dato se conecta.

5. TOPOLOGÍA DE RED IDENTIFICADA

La red objetivo es un único segmento plano `192.168.1.0/24` (sin VLAN de gestión separada, ver MAT-05), con 92 hosts activos confirmados (evidencia completa en §6). La tabla siguiente recoge los activos sobre los que se realizó inspección de aplicación (HTTP/HTTPS); el resto del inventario, descubierto pero no inspeccionado a este nivel por decisión de alcance, se detalla en la última fila.

HOST	IP	SERVICIOS / BANNER	CLASIFICACIÓN	EVIDENCIA	REF.
`testclient`	192.168.1.161	Máquina de pruebas (punto de acceso del ejercicio)	BAJA — no es activo de MoldTek Industrial	`ipconfig /all`	—
SERVIDOR (DC/DNS/DHCP)	192.168.1.100	DNS AD-integrado, IIS 10.0 (Digest/NTLM, sin TLS), SMB 445 abierto, FTP/Telnet cerrados, Kerberos 88/LDAP 389/LDAPS 636 abiertos (esperable en un DC), **RDP 3389 abierto y accesible desde la red general**	ALTA — infraestructura núcleo	`nslookup`, `curl`, `Test-NetConnection`	MI2/MI3/MI4, MAT-01/MAT-02/MAT-07
Hipervisor ESXi (grupo A)	192.168.1.245, .254	ESXi Host Client HTML5, CSP `block-all-mixed-content`	MEDIA — hipervisor de producción	`curl -i -k -L`	MAT-03

Hipervisor ESXi (grupo B)	192.168.1.249, .250	ESXi Host Client HTML5, CSP `upgrade-insecure-requests` (build distinto al grupo A)	**MEDIA** — hipervisor de producción	`curl -i -k -L`	MAT-03
Impresora Canon LBP710Cx	192.168.1.10	Interfaz de gestión HTTP (80→8000), login admin sin TLS	**MEDIA** — credenciales de admin en claro	`curl -i`	MAT-04
NAS QNAP	192.168.1.98	QTS (redirige a HTTPS correctamente), FTP cerrado, SMB y NFS abiertos (función normal del NAS)	**BAJA** — panel bien configurado; SMB/NFS refuerzan MAT-05	`curl -i -k`, `Test-NetConnection`	MAT-05
iDRAC (gestión remota de servidor físico)	192.168.1.112	iDRAC9, HSTS+preload, CSP estricta	**ALTA** — gestión fuera de banda de hardware	`curl -i -k`	MAT-05
Servidor Ubuntu/Apache sin identificar	192.168.1.244	Apache 2.4.58, página por defecto sin configurar	**MEDIA** — activo sin dueño claro, CVE sin parchear	`curl -i`	MAT-06
[Resto de 85 hosts del inventario ARP (MI1): puestos de usuario, impresoras adicionales, teléfonos DECT, switches/APs — pendientes de inspección de aplicación si se amplía el ejercicio. Lista completa de IPs/MAC en la evidencia de MI1, §6.]					

6. DESARROLLO DEL RECONOCIMIENTO

El acceso a la red se realizó desde una máquina de pruebas Windows (`testclient`, `192.168.1.161`) conectada por Ethernet al segmento objetivo. Antes de lanzar ningún escaneo activo se documentó la propia posición en la red con `ipconfig /all`, confirmando el rango de trabajo (`192.168.1.0/24`), la puerta de enlace (`192.168.1.1`) y, de forma pasiva, el servidor DHCP/DNS interno (`192.168.1.100`, concesión de 15 días) — este dato pasivo cierra ya MI3 sin necesidad de ninguna prueba activa adicional.

```
C:\Users\rdp.prueba>ipconfig /all

Configuración IP de Windows

   Nombre de host. . . . . . . . . . : testclient
   Sufijo DNS principal  . . . . . . : local.internal
   Tipo de nodo. . . . . . . . . . . : híbrido
   Enrutamiento IP habilitado. . . . : no
   Proxy WINS habilitado . . . . . . : no
   Lista de búsqueda de sufijos DNS: local.internal

Adaptador de Ethernet Ethernet0:

   Sufijo DNS específico para la conexión. . : local.internal
   Descripción . . . . . . . . . . . . . . . : Intel(R) 82574L Gigabit Network Connection
   Dirección física. . . . . . . . . . . . . : 00-50-56-8E-AB-36
   DHCP habilitado . . . . . . . . . . . . . : sí
   Configuración automática habilitada . . . : sí
   Dirección IPv4. . . . . . . . . . . . . . : 192.168.1.161(Preferido)
   Máscara de subred . . . . . . . . . . . . : 255.255.255.0
   Concesión obtenida. . . . . . . . . . . . : martes, 6 de octubre de 2026 12:37:17
   La concesión expira . . . . . . . . . . . : miércoles, 21 de octubre de 2026 12:37:17
   Puerta de enlace predeterminada . . . . . : 192.168.1.1
   Servidor DHCP . . . . . . . . . . . . . . : 192.168.1.100
   Servidores DNS. . . . . . . . . . . . . . : 192.168.1.100
   NetBIOS sobre TCP/IP. . . . . . . . . . . : habilitado
```

Para MI1 se descartó el barrido ICMP estándar: ni la puerta de enlace (`192.168.1.1`) ni los primeros hosts probados respondieron a `ping`, señal de que el Firewall de Windows bloquea ICMP por defecto en los equipos de la red (comportamiento de fábrica, no una mala configuración en sí). En su lugar se forzó la resolución a nivel de enlace con un ping a la dirección de broadcast (`192.168.1.255`) seguido de lectura de la caché ARP — la resolución ARP no depende de que el host responda a ICMP, así que revela el host igualmente:

```
C:\Users\rdp.prueba>arp -a

Interfaz: 192.168.1.161 --- 0xa
  Dirección de Internet          Dirección física      Tipo
  192.168.1.1           68-cc-ae-9b-ce-f4     dinámico
  192.168.1.2           d8-b3-70-58-11-7d     dinámico
  192.168.1.3           9c-05-d6-4c-70-75     dinámico
  [...]
  192.168.1.100         00-50-56-8e-8f-19     dinámico
  [...]
  192.168.1.254         d4-ae-52-85-92-81     dinámico
```

92 hosts activos confirmados por tabla ARP (direcciones MAC distintas, tipo `dinámico`), sobre un rango `/24` de 254 direcciones posibles — cierra MI1. El dato es coherente por orden de magnitud con la cifra de referencia del contexto inicial (~109), la diferencia se atribuye a hosts apagados o inactivos en el momento del escaneo, no a un fallo de método.

Sobre el servidor principal (`192.168.1.100`), además del SMB ya documentado (MAT-01), se comprobó el perfil de puertos propio de un Controlador de Dominio Active Directory, con `Test-NetConnection` puerto a puerto (no intrusivo: solo confirma si el puerto responde, sin autenticación ni envío de credenciales):

```
C:\Users\rdp.prueba>powershell -Command "Test-NetConnection -ComputerName 192.168.1.100 -
Port 88 -InformationLevel Quiet -WarningAction SilentlyContinue"
True

C:\Users\rdp.prueba>powershell -Command "Test-NetConnection -ComputerName 192.168.1.100 -
Port 389 -InformationLevel Quiet -WarningAction SilentlyContinue"
True

C:\Users\rdp.prueba>powershell -Command "Test-NetConnection -ComputerName 192.168.1.100 -
Port 636 -InformationLevel Quiet -WarningAction SilentlyContinue"
True

C:\Users\rdp.prueba>powershell -Command "Test-NetConnection -ComputerName 192.168.1.100 -
Port 3389 -InformationLevel Quiet -WarningAction SilentlyContinue"
True

C:\Users\rdp.prueba>powershell -Command "Test-NetConnection -ComputerName 192.168.1.100 -
Port 3268 -InformationLevel Quiet -WarningAction SilentlyContinue"
True

C:\Users\rdp.prueba>powershell -Command "Test-NetConnection -ComputerName 192.168.1.100 -
Port 139 -InformationLevel Quiet -WarningAction SilentlyContinue"
True
```

Kerberos (88), LDAP (389), LDAPS (636), Catálogo Global (3268) y NetBIOS (139) abiertos son normales y necesarios para el funcionamiento de un Controlador de Dominio — no constituyen hallazgo por sí mismos. El puerto 3389 (RDP) abierto y accesible desde el mismo segmento que los puestos de usuario sí se documenta como hallazgo (MAT-07), ver §7. Con esto se da por cerrado el perfil de puertos/servicios de AD relevante para este ejercicio.

Sobre vulnerabilidades conocidas del sistema operativo o de la configuración de acceso de los demás activos: más allá del CVE confirmado en el servidor Apache (MAT-06), no fue posible identificar de forma fiable ninguna otra vulnerabilidad específica (CVE) en el sistema operativo de SERVIDOR, el firmware del NAS, de la impresora o del iDRAC, porque ninguno de los banners obtenidos de forma no intrusiva

revela una versión de build exacta — solo el producto/modelo (ver limitación ya señalada en MAT-03 para ESXi). Citar un CVE concreto sin esa versión exacta sería una suposición, no una verificación, y este informe ha evitado precisamente ese error (ver la corrección del dato "VMware ESX 4.0" en MAT-03). Como contraste, se comprobó puntualmente si el CVE-2021-20877 (XSS en interfaces de gestión de varias impresoras Canon imageCLASS/LBP) afecta al modelo aquí identificado: según el propio aviso del fabricante, el **LBP710Cx no está entre los modelos afectados** — se descarta explícitamente en vez de darlo por bueno o por malo sin comprobar.

Como prueba adicional de MI4 (protocolos obsoletos → TLS obsoleto), se intentó forzar una negociación TLS 1.0 contra el NAS (`192.168.1.98`):

```
C:\Users\rdp.prueba>curl.exe -i -k --tlsv1.0 --tls-max 1.0 https://192.168.1.98/
curl: (35) schannel: next InitializeSecurityContext failed: SEC_E_UNSUPPORTED_FUNCTION
(0x80090302) - No se permite la función solicitada
```

Resultado no concluyente: el error es del lado cliente (el stack TLS de la máquina de pruebas, Schannel, tiene TLS 1.0 deshabilitado a nivel de sistema operativo y rechaza negociarlo antes de que la petición llegue al servidor). No es posible, por tanto, determinar desde este puesto si el NAS acepta o rechaza TLS 1.0 — se documenta la limitación en lugar de inferir un resultado. Confirmarlo exigiría repetir la prueba desde un cliente con TLS 1.0 habilitado explícitamente, o revisar la configuración del NAS con acceso administrativo. Por el mismo motivo (backend Schannel, no OpenSSL), `curl.exe -vk` tampoco expone el certificado presentado por los hosts HTTPS inspeccionados (asunto/emisor/caducidad) — limitación de la herramienta disponible en este puesto, no un dato sobre el objetivo.

Sobre posible exposición de correo: se comprobaron los puertos SMTP (25) y submission (587) en SERVIDOR — ambos **cerrados**, sin servidor de correo expuesto en el Controlador de Dominio. El puerto 443 también respondió abierto en SERVIDOR; no se pudo identificar el servicio exacto detrás (inestabilidad puntual de la consola del puesto de pruebas al intentar el `curl`) — dado que SERVIDOR ya aloja IIS en el puerto 80, lo más probable es que sea el mismo IIS en HTTPS, pero se deja constancia de que no se confirmó con evidencia propia, en vez de asumirlo.

Por último, se amplió el perfil de puertos del NAS más allá de su panel web:

```
C:\Users\rdp.prueba>powershell -Command "Test-NetConnection -ComputerName 192.168.1.98 -
Port 21 -InformationLevel Quiet -WarningAction SilentlyContinue"
False

C:\Users\rdp.prueba>powershell -Command "Test-NetConnection -ComputerName 192.168.1.98 -
Port 445 -InformationLevel Quiet -WarningAction SilentlyContinue"
True

C:\Users\rdp.prueba>powershell -Command "Test-NetConnection -ComputerName 192.168.1.98 -
Port 2049 -InformationLevel Quiet -WarningAction SilentlyContinue"
True
```

FTP (21) cerrado; SMB (445) y NFS (2049) abiertos. Esto no se clasifica como hallazgo nuevo — son los protocolos de compartición de ficheros que constituyen la función principal de un NAS, no una desviación de lo esperado. Sí refuerza MAT-05: un NAS con SMB/NFS activos en el mismo segmento plano que los puestos de usuario, sin VLAN de gestión, amplifica el impacto de esa falta de segmentación. Comprobar si existen recursos compartidos accesibles sin autenticación sería el siguiente paso lógico, pero queda fuera de alcance por la misma razón que la sesión SMB anónima en SERVIDOR (§9): es un intento de acceso, aunque no use contraseña real.

7. HALLAZGOS TÉCNICOS

CVSS 3.1 cuando aplica. Formato de ficha idéntico al usado en el informe de latabernademo.com.

MAT-01 · SMB expuesto en el servidor principal sin confirmar versión

BAJO (A REVISAR) CWE-200

Evidencia: `Test-NetConnection -ComputerName 192.168.1.100 -Port 445` → `TcpTestSucceeded: True`.

Riesgo: puerto SMB accesible desde el segmento de usuarios; sin herramienta de huella de protocolo (Nmap) disponible en el puesto de pruebas no se puede confirmar a distancia si el servidor permite SMBv1 (vector histórico de EternalBlue/WannaCry) o solo SMBv2/v3.

Remediación: confirmar con acceso administrativo al propio servidor (`Get-SmbServerConfiguration`) y deshabilitar SMBv1 si estuviera activo.

MAT-02 · Servidor IIS interno sin TLS (HTTP puro)

BAJO CWE-319

Evidencia: `curl.exe -i http://192.168.1.100` →

```
HTTP/1.1 401 Unauthorized
Server: Microsoft-IIS/10.0
WWW-Authenticate: Digest qop="auth",algorithm=MD5-sess,nonce="...",charset=utf-
8,realm="Digest"
WWW-Authenticate: Negotiate
WWW-Authenticate: NTLM
```

Interpretación: la autenticación ofrecida es Digest/Negotiate/NTLM — ninguna transmite la contraseña en texto claro, así que esto **no** es un caso de credenciales expuestas (MI5). El problema es más limitado: todo el tráfico posterior a la autenticación (sesión, contenido) circula sin cifrar al no haber TLS en el puerto 80.

Remediación: forzar HTTPS con certificado válido (interno o de CA propia) y redirigir 80→443.

MAT-03 · Hipervisor ESXi expuesto, versión exacta sin confirmar por vía pasiva

INFORMATIVO CWE-200

Evidencia:

```
$ curl.exe -i http://192.168.1.245
HTTP/1.1 301 Moved Permanently
Location: https://192.168.1.245/

$ curl.exe -i -k https://192.168.1.245/
HTTP/1.1 200 OK
Content-Security-Policy: block-all-mixed-content
Strict-Transport-Security: max-age=31536000
X-Content-Type-Options: nosniff
X-Frame-Options: DENY
<meta http-equiv="refresh" content="0;URL='/ui'"/>

$ curl.exe -i -k https://192.168.1.245/ui/
HTTP/1.1 200 OK
[...]
<html class="no-js vui-layout-html" ng-app="esxUiApp">
[...]
<script src="bower_components/requirejs/require.js" data-main="scripts/main"></script>
```

Corrección respecto al contexto inicial del ejercicio: el host se había referenciado como "VMware ESX 4.0 Server httpd". La evidencia propia lo contradice: `/ui` con `esxUiApp` (Angular) y cabeceras de seguridad modernas (CSP, HSTS, X-Frame-Options) corresponden al **ESXi Host Client HTML5**, introducido en ESXi 6.0 (2015) — una versión EOL de 2010 nunca tuvo esta interfaz. El dato original estaba desactualizado o era incorrecto; el hipervisor real es considerablemente más moderno.

Pendiente: la versión de build exacta no se puede fijar por recon pasivo/no intrusivo (ESXi oculta el `Server` header desde 6.x); se necesitaría acceso administrativo (`vCenter` o SSH al host) para el cruce con CVE de MI6.

Los otros tres hosts con la misma huella original ("VMware ESX 4.0") se confirmaron también como ESXi Host Client moderno, pero con una diferencia relevante en la cabecera `Content-Security-Policy` que delata al menos dos niveles de parcheo distintos dentro del mismo clúster:

HOST	CONTENT-SECURITY-POLICY	GRUPO DE BUILD
192.168.1.245	`block-all-mixed-content`	A
192.168.1.254	`block-all-mixed-content`	A

192.168.1.249	`upgrade-insecure-requests`	B
192.168.1.250	`upgrade-insecure-requests`	B

Riesgo: un clúster de hipervisores con parches desiguales sugiere falta de gestión centralizada de actualizaciones (sin Lifecycle Manager o sin aplicarlo de forma uniforme) — el host con el build más antiguo del grupo es, por definición, el que concentra más CVE sin corregir.

Remediación: confirmar build exacto de cada host con acceso administrativo y uniformizar el nivel de parche en todo el clúster.

MAT-04 · Credenciales de administración de impresora en texto claro (HTTP)

MEDIO CWE-319 / CWE-523 · CVSS 3.1: **5.9** (`AV:A/AC:L/PR:N/UI:R/S:U/C:H/I:N/A:N` — vector ajustado a acceso adyacente, ya que requiere estar en el mismo segmento de red)

Evidencia: impresora Canon LBP710Cx (`192.168.1.10`), interfaz de gestión remota.

```
$ curl.exe -i http://192.168.1.10/
<SCRIPT>...top.document.location.href = "http://192.168.1.10:8000/rps/login.cgi";
</SCRIPT>

$ curl.exe -i http://192.168.1.10:8000/rps/login.cgi
HTTP/1.1 200 OK
Server: Catwalk
[...]
<form name="login" action="/login" method="post" autocomplete="off">
  ...
  <input type="password" name="password" id="password" ... />
  ...
  <input type="radio" id="radio1" name="login_mode" value="admin" />Modo de gestión
```

Riesgo: el formulario de "Modo de gestión" (administrador) envía la contraseña por `POST` sin que exista HTTPS en ningún puerto del dispositivo (ni 80 ni 8000) — cualquiera en el mismo segmento de red con capacidad de capturar tráfico (fuera del alcance de este ejercicio, pero trivial de hacer) obtendría la contraseña de administración del dispositivo en claro.

Remediación: habilitar HTTPS en la interfaz de gestión del dispositivo (la mayoría de impresoras Canon de esta gama lo soportan con certificado autofirmado) y forzar la redirección; si no es posible, restringir el acceso a la interfaz de gestión a una VLAN de administración separada.

MAT-05 · Sin segmentación de red entre puestos de usuario e interfaces de gestión crítica

MEDIO CWE-1008 (arquitectura de seguridad deficiente)

Evidencia: iDRAC (`192.168.1.112`), los 4 hipervisores ESXi (`.245/.249/.250/.254`) y la consola del NAS (`.98`) responden en el mismo rango `192.168.1.0/24` que los puestos de trabajo de usuario (`PC-Usuario06`, `PC-Usuario07`, `PC-Usuario02`...), confirmado por la tabla ARP de MI1 — no hay ninguna VLAN de gestión separada visible desde este punto de la red.

Riesgo: cada interfaz individual puede estar bien configurada (iDRAC y NAS, en este caso, tienen cabeceras de seguridad correctas), pero al no existir segmentación, cualquier equipo de usuario comprometido tiene conectividad L3 directa a la gestión fuera de banda de servidores físicos (iDRAC), a los hipervisores y al NAS — un solo punto de apoyo en cualquier puesto da acceso a toda la infraestructura crítica.

Remediación: crear una VLAN de gestión dedicada para iDRAC/ESXi/NAS, con acceso restringido por firewall solo desde los puestos de administración de sistemas.

MAT-06 · Servidor Ubuntu/Apache sin configurar, con CVE conocido pendiente de parche

MEDIO CWE-1188 (recurso desplegado con configuración por defecto) · CVE-2024-24795, CVSS 3.1: **6.3** (`AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:L`)

Evidencia:

```
$ curl.exe -i http://192.168.1.244/
HTTP/1.1 200 OK
Server: Apache/2.4.58 (Ubuntu)
Last-Modified: Mon, 10 Feb 2025 11:10:45 GMT
[...]
<title>Apache2 Ubuntu Default Page: It works</title>
```

Interpretación: el servidor responde con la página de bienvenida por defecto de Apache en Ubuntu — nunca se completó el despliegue del sitio real, o es un servidor olvidado. Versión cruzada contra NVD/Rapid7: 2.4.58 queda por debajo del parche de **CVE-2024-24795** (HTTP response splitting, CVSS 6.3, corregido en 2.4.59).

Riesgo: doble — (1) gestión de activos deficiente (servidor desplegado y olvidado, sin dueño claro); (2) CVE medio sin corregir, explotable si en algún momento se expone una aplicación real detrás de este Apache sin actualizar antes.

Remediación: identificar al propietario/propósito de este servidor y, si no está en uso, darlo de baja; si está en uso, actualizar Apache a 2.4.59+ antes de publicar ningún contenido real.

MAT-07 · Interfaz de administración remota (RDP) del Controlador de Dominio expuesta en la red general

MEDIO CWE-1008 (arquitectura de seguridad deficiente)

Evidencia:

```
C:\Users\rdp.prueba>powershell -Command "Test-NetConnection -ComputerName
192.168.1.100 -Port 3389 -InformationLevel Quiet -WarningAction SilentlyContinue"
True
```

Interpretación: el puerto 3389 (RDP) del Controlador de Dominio responde desde el mismo segmento `192.168.1.0/24` donde están los puestos de usuario, la impresora y el resto de equipos — no hay restricción de acceso visible desde este punto de la red. No se ha intentado autenticación, fuerza bruta ni ningún otro paso más allá de confirmar que el puerto responde (fuera de alcance de este ejercicio).

Riesgo: el Controlador de Dominio es el activo más crítico de la red (concentra credenciales e identidad de todo el dominio). Exponer su interfaz de administración remota al mismo segmento que los puestos de usuario — en vez de restringirla a una red de gestión o a un salto administrativo (jump host) — amplía la superficie de ataque: cualquier puesto de usuario comprometido puede intentar autenticarse directamente contra RDP del DC, incluyendo ataques de fuerza bruta o pulverización de contraseñas si existieran credenciales débiles (no verificado ni probado en este ejercicio).

Verificación adicional: se comprobó si el DC exige Autenticación a Nivel de Red (NLA) conectando con el cliente de Escritorio remoto estándar (`mstsc`) sin introducir ninguna credencial real. El cuadro "Seguridad de Windows — Escribir las credenciales" apareció *antes* de mostrar cualquier pantalla de escritorio o de inicio de sesión de Windows, lo que confirma que **NLA está activo**. Esto mitiga parte del riesgo (reduce la superficie de pre-autenticación, protege frente a clases de vulnerabilidad como CVE-2019-0708/BlueKeep), pero no elimina el hallazgo: NLA protege la negociación, no sustituye a la segmentación — el puerto sigue siendo alcanzable desde cualquier puesto de usuario comprometido, que podría intentar autenticarse con credenciales robadas igualmente.

Remediación: restringir el acceso RDP al Controlador de Dominio mediante firewall a un conjunto limitado de puestos de administración (jump host/bastión), o a una VLAN de gestión dedicada — mismo principio que MAT-05. NLA ya está correctamente activo; mantenerlo y considerar además políticas de bloqueo de cuenta ante intentos fallidos repetidos.

Correlación con MITRE ATT&CK

Cada hallazgo se asocia a la técnica (Enterprise Matrix) que describiría su explotación o el riesgo que habilita — no implica que se haya ejecutado esa técnica, solo señala el vector al que queda expuesto el activo.

HALLAZGO	TÁCTICA	TÉCNICA MITRE ATT&CK	POR QUÉ
MAT-01	Discovery	T1046 — Network Service Discovery	Puerto SMB visible y enumerable desde la red; si fuera SMBv1, habilitaría además T1210
MAT-02	Credential Access / Collection	T1040 — Network Sniffing	Tráfico posterior a la autenticación sin cifrar, interceptable por cualquiera en el mismo segmento
MAT-03	Lateral Movement (habilitador)	T1210 — Exploitation of Remote Services	Un hipervisor sin parchear de forma uniforme es la condición previa que esta técnica explota
MAT-04	Credential Access	T1040 / T1557 — Network Sniffing / Adversary-in-the-Middle	Credenciales de administración viajan en claro por HTTP, capturables sin interacción del usuario
MAT-05	Lateral Movement	T1021 — Remote Services	La falta de segmentación es lo que permite que el compromiso de un puesto de usuario alcance directamente la infraestructura crítica
MAT-06	Initial Access	T1190 — Exploit Public-Facing Application	CVE-2024-24795 sin parchear en un servicio expuesto es la vía de entrada que describe esta técnica
MAT-07	Lateral Movement / Credential Access	T1021.001 — Remote Desktop Protocol; T1110 — Brute Force (riesgo derivado)	RDP del DC accesible desde la red general es el vector de entrada típico de esta técnica; sin control de intentos, habilita además fuerza bruta

8. COBERTURA Y CIERRE

PUNTO	ESTADO	DETALLE
MI1 — Topología	HECHO	92 hosts activos confirmados por tabla ARP sobre 192.168.1.0/24
MI2 — DNS interno	CERRADO	Zona AD-integrada `local.internal`; AXFR correctamente rechazado (`Query refused`) — sin hallazgo
MI3 — DHCP	CERRADO	Confirmado de forma pasiva (`ipconfig /all`) — servidor 192.168.1.100, sin indicio de mala configuración

MI4 — Protocolos obsoletos	**PARCIAL**	FTP/Telnet cerrados en SERVIDOR; SMB (445) abierto sin confirmar versión (MAT-01); HTTP sin TLS en dos hosts (MAT-02, MAT-06)
MI5 — Credenciales en tránsito inseguro	**HECHO**	1 caso confirmado (impresora, MAT-04); servidor IIS descartado (autenticación sin texto claro)
MI6 — Vulnerabilidades del escaneo	**PARCIAL**	1 CVE confirmado (Apache 2.4.58, MAT-06); ESXi con build desigual sin CVE fijado por falta de versión exacta (MAT-03)
Hosts con inspección de aplicación (HTTP/HTTPS)	**7 DE 92**	SERVIDOR (.100), 4× ESXi (.245/.249/.250/.254), impresora (.10), NAS (.98), iDRAC (.112), Apache (.244) — resto del inventario pendiente de la misma pasada si se amplía el ejercicio
TLS obsoleto	**NO CONCLUYENTE**	Prueba forzando TLS 1.0 contra el NAS bloqueada por el propio cliente de pruebas (Schannel) antes de llegar al servidor — no se pudo determinar el comportamiento real del objetivo
Perfil de puertos AD en el Controlador de Dominio	**HECHO**	Kerberos/LDAP/LDAPS/Catálogo Global/NetBIOS correctos y esperables; RDP expuesto a la red general sin restricción (MAT-07)
CVE/vulnerabilidades del OS o firmware (SERVIDOR, NAS, impresora, iDRAC)	**NO VIABLE**	Sin versión de build exacta en ninguno de los cuatro por banner no intrusivo, no se puede verificar CVE específico sin suponer versión; se descartó puntualmente CVE-2021-20877 para la impresora (modelo no afectado según el fabricante)
Certificados TLS (asunto/emisor/caducidad)	**NO VIABLE**	`curl.exe` en este puesto usa Schannel, no OpenSSL, y no expone el certificado en modo `-v` — limitación de herramienta, no del objetivo
Perfil de servicios del NAS más allá del panel web	**HECHO**	FTP cerrado; SMB y NFS abiertos (función normal del NAS) — refuerza MAT-05
Exposición de correo (SMTP) en SERVIDOR	**CERRADO**	Puertos 25/587 cerrados, sin servidor de correo expuesto — sin hallazgo. Puerto 443 abierto pero sin identificar el servicio exacto (inestabilidad de consola, no forzado)
NLA en RDP del Controlador de Dominio	**HECHO**	Confirmado activo (prompt de credenciales antes de cualquier escritorio) — matiza MAT-07 sin eliminarlo

9. DECISIONES Y LÍMITES DE ALCANCE

- **Por qué no se fue más allá del reconocimiento:** el alcance autorizado cubre únicamente enumeración y análisis de configuración visible, sin explotación. Cualquier prueba de acceso, fuerza bruta o explotación de un CVE identificado exigiría autorización explícita adicional y ventana de mantenimiento acordada.

- **Nivel de agresividad:** ajustado a la baja de forma deliberada — red de producción real con equipos frágiles (hipervisores sin soporte, equipo embebido) donde un escaneo agresivo podría afectar al servicio; se prioriza el timing conservador y la ausencia de categorías NSE intrusivas sobre la cobertura exhaustiva de puertos.
- **Phishing / ingeniería social — fuera de alcance por diseño, no por límite de herramienta:** MSA-Interno es una metodología de reconocimiento de red, no una campaña de ingeniería social. Evaluar la susceptibilidad real al phishing exigiría otro tipo de ejercicio por completo (envío de correos de prueba a empleados reales), con su propia autorización específica, independiente de la autorización de reconocimiento de red de este informe. No se asume ni se insinúa ningún resultado al respecto.
- **Contexto adicional no verificado, aportado por el reconocimiento previo del compañero (no por este equipo):** su inventario señala un posible equipo de automatización industrial (marca no identificada, grupo NetBIOS "GRUPO-IND", `192.168.1.129` y `192.168.1.232`) en el mismo segmento que los puestos de usuario — si se confirmara, reforzaría MAT-05 al añadir maquinaria de producción (OT) a la lista de infraestructura crítica sin segmentar. También señala carpetas compartidas (incluida una de software de contabilidad) y nombres de usuario local enumerables por SMB en varios servidores. Se intentó verificar de forma independiente el primer punto (`curl` contra los dos hosts) pero `curl.exe` dejó de funcionar en el puesto de pruebas durante esta sesión (fallo incluso en `curl.exe --version`), por lo que no se pudo completar. El segundo punto (enumeración SMB) ni se intentó, por ser el mismo tipo de prueba de acceso ya excluido en el punto anterior de esta lista. Ambos quedan como contexto sin verificar por este equipo, no como hallazgos MAT-XX.
- **Qué haría falta con autorización, herramientas o acceso adicional:**
  - *SNMP con community string por defecto ("public")* — chequeo no intrusivo habitual en este tipo de ejercicio, pero no evaluado aquí por no disponer de herramienta cliente SNMP en el puesto de pruebas (mismo tipo de limitación que impidió el fingerprinting con Nmap).
  - *Sesión SMB anónima/invitado (null session)* — deliberadamente no probada: aunque no requiere contraseña real, es un intento de autenticación y las reglas de compromiso de este ejercicio excluyen explícitamente cualquier prueba de credenciales.
  - *Red Wi-Fi corporativa* — no evaluable desde este puesto de pruebas, conectado por Ethernet sin interfaz inalámbrica; requeriría un cliente Wi-Fi y autorización específica si MoldTek Industrial dispone de red inalámbrica.
  - *Versión exacta de SO/firmware* (SERVIDOR, ESXi, NAS, impresora, iDRAC) y *dialecto SMB exacto* (MAT-01) — exigen acceso administrativo al activo o herramienta de fingerprinting activo (Nmap), fuera del alcance no intrusivo de este ejercicio.
  - *Explotación de cualquier CVE identificado* (p. ej. MAT-06) — exigiría autorización explícita adicional y ventana de mantenimiento acordada; no se intenta en ningún caso dentro de este

reconocimiento.

ANEXOS

A. MARCO NORMATIVO APLICABLE

ESTÁNDAR / NORMA	CÓMO APLICA AQUÍ
RGPD + LOPDGDD	Art. 32 — medidas técnicas de seguridad de la red que trata datos personales (si algún host maneja PII de empleados/clientes, a confirmar en el inventario)
ISO/IEC 27001:2022 (Anexo A)	A.8.9 gestión de configuración; A.8.20-8.22 seguridad de redes y segmentación; A.8.24 criptografía/TLS
ENS (RD 311/2022) + guías CCN-STIC	op.mon — monitorización; mp.com — protección de comunicaciones; op.exp.4 — mantenimiento de software. Voluntario para una empresa privada, exigible si presta servicio a sector público
NIS2 (Directiva (UE) 2022/2555, transposición española pendiente/en curso)	Solo aplicaría si MoldTek Industrial encaja como entidad "esencial" o "importante" de alguno de los 18 sectores del Anexo I/II (energía, salud, digital, manufactura crítica...) y supera los umbrales de tamaño (≥50 empleados o ≥10M€ de facturación) — no se ha confirmado el sector/tamaño exacto de MoldTek Industrial en este ejercicio, así que se cita como marco a verificar, no como obligación confirmada. Si aplicara, los hallazgos MAT-05 y MAT-07 (segmentación, exposición de gestión remota) son exactamente el tipo de medida técnica que exige (gestión de riesgos, control de acceso)
MITRE ATT&CK (Enterprise Matrix)	Marco de referencia para correlacionar cada hallazgo con la técnica de ataque que describe su explotación o el riesgo que habilita — ver tabla de correlación en §7
CIS Controls v8	Control 4 (Configuración segura) — MAT-02/MAT-04/MAT-06; Control 12 (Gestión de infraestructura de red) — MAT-05/MAT-07, directamente aplicable a la falta de segmentación y a la exposición de RDP del DC
Metodología de referencia	PTES, NIST SP 800-115, CVSS 3.1, catálogo CWE

Esta sección es orientativa, con fines formativos y de GRC — no constituye asesoramiento legal.

B. GLOSARIO

TÉRMINO	SIGNIFICADO
MAT-XX	Identificador correlativo de cada hallazgo de este informe. Numeración propia del ejercicio, no un estándar externo
MSA-Interno	Adaptación de la metodología MSA-Recon (M1-M6, usada en el informe de latabernademo.com) a un escenario de reconocimiento de red interna (MI1-MI6)
SMBv1	Versión obsoleta del protocolo de compartición de ficheros de Windows, sin soporte desde 2014 y origen de vulnerabilidades críticas (p. ej. EternalBlue/WannaCry)
AXFR	Transferencia de zona DNS — si un servidor la permite sin restricción, expone toda su configuración de dominio a cualquiera que la solicite
CVSS	Common Vulnerability Scoring System — puntuación de severidad de vulnerabilidades (0-10)
CWE	Common Weakness Enumeration — catálogo de tipos de debilidad de software
iDRAC	Integrated Dell Remote Access Controller — interfaz de gestión remota fuera de banda de servidores Dell; un acceso expuesto aquí equivale a control total del servidor físico
MITRE ATT&CK	Catálogo público de tácticas y técnicas de ataque reales, mantenido por MITRE; usado aquí para indicar a qué técnica concreta queda expuesto cada hallazgo (p. ej. T1021.001 para RDP), no para afirmar que esa técnica se haya ejecutado
NIS2	Directiva (UE) 2022/2555 sobre ciberseguridad, sucesora de NIS — aplica a entidades "esenciales" o "importantes" de ciertos sectores por encima de un umbral de tamaño; aplicabilidad a MoldTek Industrial no confirmada en este ejercicio

C. REFERENCIAS

- PTES — Penetration Testing Execution Standard
- NIST SP 800-115 — Technical Guide to Information Security Testing and Assessment
- ISO/IEC 27001:2022 — Anexo A
- ENS (RD 311/2022) y guías CCN-STIC
- FIRST — CVSS 3.1 Specification Document
- MITRE — catálogo CWE y MITRE ATT&CK (Enterprise Matrix)
- Directiva (UE) 2022/2555 (NIS2)
- CIS Controls v8 (Center for Internet Security)

Estructura y nivel de detalle alineados con el informe de reconocimiento externo de latabernademo.com, adaptados a un escenario de red interna (MSA-Interno, MI1-MI6). Evidencia propia del ejercicio recogida en su totalidad en la Parte II.